

PLANTILLA P60 · INFORME DE AUDITORÍA Y FICHAS DE HALLAZGO

# Informe de auditoría y fichas de hallazgo

Comunica el resultado de una auditoría de IA con opinión, alcance, limitaciones, hallazgos clasificados, recomendaciones y respuesta de la dirección, en un formato que la dirección y el consejo pueden leer y seguir.

## EN ESTE DOCUMENTO

01 Instrucciones de uso

02 Identificación

03 Resumen para la dirección

04 Objetivo, alcance y criterios

05 Limitaciones

06 Metodología

07 Resumen de hallazgos

08 Fichas de hallazgo

09 Observaciones y recomendaciones

10 Seguimiento de hallazgos anteriores

11 Respuesta de la dirección

12 Conclusión

13 Distribución y anexos

14 Criterios de calidad

15 Aprobación y verificación

16 Control de versiones

**Aviso legal y exención de responsabilidad.** SEVEN-G es un marco metodológico de referencia que se ofrece «tal cual» y con fines exclusivamente informativos. No constituye asesoramiento jurídico, regulatorio, financiero ni profesional, ni garantiza el cumplimiento de ninguna norma. Las referencias a regulación general (como el Reglamento Europeo de IA, el RGPD, DORA o NIS2), a normas técnicas y a regulación específica de cada sector o jurisdicción pueden ser incompletas, no aplicar a un caso concreto o quedar desactualizadas por cambios normativos, interpretaciones o criterios de las autoridades posteriores a su fecha de consulta. **Cada organización que use SEVEN-G es la única responsable de identificar la normativa que le aplica, verificar su vigencia y certificar su propio cumplimiento regulatorio**, con el asesoramiento cualificado que corresponda. Esta metodología es una ayuda genérica y gratuita, compartida con la comunidad para que nadie tenga que empezar desde cero; cada persona u organización puede y debe adaptarla a su propio uso. No debe entenderse que sus partes jurídicamente sensibles hayan sido revisadas por una asesoría jurídica: esas revisiones, para cada empresa o sector, son responsabilidad última de la empresa, el consultor o la organización que la use. Aunque se procura mantenerla al día, alguna norma puede haber cambiado sin que se recoja aquí. En la máxima medida permitida por la ley, el autor no asume responsabilidad alguna por los efectos de su aplicación en ninguna organización ni por su aplicabilidad completa. La metodología no otorga certificación de ningún tipo. El autor no asume responsabilidad alguna por el uso que se haga de este contenido ni por las decisiones que se adopten con él. Los datos, cifras, compañías y casos de los ejemplos son ficticios o ilustrativos.

**Por qué importa.** El informe es lo que llega a quien decide: el órgano del *gate*, el comité de IA, la comisión delegada o el consejo. Si no separa hechos, criterio, causa y efecto, el hallazgo se discute en vez de corregirse; si no declara sus limitaciones, una conclusión Conforme aparenta más seguridad de la que tiene. Las fichas de hallazgo convierten cada incumplimiento en una acción con responsable y plazo, y enlazan con el registro de no conformidades para que nada se pierda.

# Instrucciones de uso

| Aspecto                              | Indicación                                                                                                                                                                                                                                                     |
|--------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Cuándo se usa</b>                 | Al terminar el trabajo de campo de cualquier auditoría de IA: de continuidad, del marco, temática, de proveedor, del valor y posterior a <i>gates</i> . En la verificación de un <i>gate</i> se usa la versión abreviada integrada en P29 y T03 (sección 3.1). |
| <b>Quién la rellena</b>              | El auditor principal redacta el borrador; la dirección responsable completa la sección 11 (respuesta de la dirección).                                                                                                                                         |
| <b>Quién la verifica</b>             | El responsable de auditoría de IA revisa el borrador frente a los papeles de trabajo (P59).                                                                                                                                                                    |
| <b>Quién decide o aprueba</b>        | El auditor principal emite la opinión. Las acciones las aprueba el órgano que corresponde a la clase del hallazgo (30 §8.2: oficina de IA para menores, comité de IA para mayores, comité y comisión delegada para críticas).                                  |
| <b>Etapas, <i>gate</i> o momento</b> | Según el plan anual (P58). La auditoría del marco y la del valor se incorporan a C5. Plazos orientativos (38 §6.1): borrador en 10 días hábiles tras el cierre, respuesta de la dirección en 10 y final en 5.                                                  |
| <b>Herramienta</b>                   | T08 (alta de cada no conformidad con NC-AAAA-NNN y vínculo a su auditoría de origen) · T03 y T01 (resultado de verificación y de auditoría) · T12 (auditoría del valor).                                                                                       |
| <b>Documento de referencia</b>       | Documento 38 §8–§10; documento 21 §10.2, §10.5–§10.7; documento 43 §12; documento 37.                                                                                                                                                                          |
| <b>Lite frente a Enterprise</b>      | No cambia la estructura del informe. En Lite, la verificación documental de acciones menores puede hacerla la oficina de IA (38 §10).                                                                                                                          |

## Reglas de cumplimentación:

- La auditoría se identifica con **AUD-AAAA-NNN** y cada hallazgo con **H-01, H-02...** dentro del informe (38 §9). Toda no conformidad se registra además en T08 con **NC-AAAA-NNN**.
- Se clasifica por el **efecto más grave** sobre la decisión, las personas o el cumplimiento, y se aplican las reglas de agregación y reincidencia de 38 §8.1 y 21 §10.5.
- El resultado de la auditoría **no es la decisión del *gate***: el auditor no recomienda si la iniciativa debe continuar por su valor de negocio.
- Toda no conformidad crítica se comunica **antes del informe**, en cuanto se confirma (30, E-5).
- La recomendación dice **qué** debe corregirse, no cómo diseñarlo en detalle: el auditor no diseña los controles que después audita.

# Identificación

| Campo                        | Contenido                                                                                    | Guía |
|------------------------------|----------------------------------------------------------------------------------------------|------|
| Código de la auditoría       | AUD-AAAA-NNN.                                                                                |      |
| Tipo                         | Continuidad · Marco · Temática · Proveedor · Valor · Posterior a <i>gates</i> · Reauditoría. |      |
| Objeto                       | SIA-AAAA-NNN, IA-AAAA-NNN, proveedor, proceso o tema.                                        |      |
| Periodo auditado             |                                                                                              |      |
| Fechas del trabajo           | Apertura, cierre, borrador e informe final.                                                  |      |
| Auditor principal y expertos | Con referencia a sus declaraciones de independencia (P41).                                   |      |
| Destinatarios                | Según la sección 13.                                                                         |      |
| Versión del informe          | Borrador · Final.                                                                            |      |

# Resumen para la dirección

| Campo                                  | Contenido                                                                                                                                                                 | Guía |
|----------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| Resultado                              | <b>Conforme</b> (sin no conformidades) · <b>Conforme con observaciones</b> (solo menores) · <b>No conforme</b> (al menos una mayor o crítica).                            |      |
| Hallazgos por clase                    | Críticas · mayores · menores · observaciones.                                                                                                                             |      |
| Tres mensajes principales              | En lenguaje no técnico.                                                                                                                                                   |      |
| Riesgo para la compañía si no se actúa | Decisión, personas, cumplimiento o valor afectados.                                                                                                                       |      |
| Advertencia expresa                    | Si una no conformidad menor afecta a controles críticos de seguridad, cumplimiento legal o supervisión humana, no se admite Continuar con condiciones (01 §7.3; 38 §8.2). |      |

### 3.1 Versión abreviada para la verificación de un *gate*

Se registra en P29 y T03 (38 §9.1): resultado de la verificación, criterios en No cumple o Pendiente, hallazgos y limitaciones. Con resultado No conforme, la solicitud vuelve al equipo **sin decisión** (21 §10.2).

## 04

# Objetivo, alcance y criterios

| Campo               | Contenido                                                                                                                                                                                                                                              | Guía |
|---------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| Objetivo            |                                                                                                                                                                                                                                                        |      |
| Qué se auditó       | Sistemas, versiones, iniciativas, <i>gates</i> , procesos, periodo.                                                                                                                                                                                    |      |
| Qué no se auditó    | Y por qué.                                                                                                                                                                                                                                             |      |
| Criterios aplicados | Códigos <i>Gn.nn</i> y <i>R6.nn</i> del documento 21, listas LV del documento 22, reglas EV, documentos del marco y normas aplicables (por ejemplo, el <a href="#">Reglamento de IA</a> o el <a href="#">RGPD</a> según la clasificación del sistema). |      |

## 05

# Limitaciones

| Limitación | Tipo                                                                                                                           | Efecto en la conclusión                                                                   |
|------------|--------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|
|            | Información no disponible · Acceso denegado · Prueba no realizada · Plazo · Dependencia del auditado para la evidencia técnica | Ninguno · Conclusión con salvedad sobre el área · Imposibilidad de concluir sobre el área |

## Metodología

| Campo                                          | Contenido | Guía                                                                  |
|------------------------------------------------|-----------|-----------------------------------------------------------------------|
| Técnicas usadas                                |           | 38 §7.1.                                                              |
| Poblaciones, muestras y método de selección    |           | Resumen del registro de P59 §7.4.                                     |
| Pruebas técnicas y versión del sistema probado |           | 38 §7.3.                                                              |
| Trabajo de terceros utilizado                  |           | Informe, autor, fecha y evaluación de su independencia y competencia. |

## Resumen de hallazgos

### 7.1 Por clasificación

| Clase                  | Número | Códigos | Contención (38 §8.1)                                           | Plan de acción                             | Informa a                        |
|------------------------|--------|---------|----------------------------------------------------------------|--------------------------------------------|----------------------------------|
| No conformidad crítica |        |         | Inmediata, máximo 48 horas, incluida la parada si es necesario | Máximo 10 días                             | Comité de IA y comisión delegada |
| No conformidad mayor   |        |         | Máximo 10 días                                                 | Máximo 30 días                             | Comité de IA                     |
| No conformidad menor   |        |         | No requerida                                                   | Antes del siguiente <i>gate</i> o revisión | Oficina de IA                    |
| Observación            |        |         | —                                                              | La dirección decide si actúa               | —                                |

Los plazos son de referencia; la compañía puede ajustarlos en C2 sin superar los que fije la regulación.

### 7.2 Resultado por elemento auditado

Obligatorio en auditorías posteriores de *gates* y en las temáticas con varios sistemas (21 §10.7).

| Elemento (iniciativa, <i>gate</i> , sistema o proveedor) | Resultado                                           | Hallazgos |
|----------------------------------------------------------|-----------------------------------------------------|-----------|
|                                                          | Conforme · Conforme con observaciones · No conforme |           |

08

## Fichas de hallazgo

Una ficha por hallazgo (38 §9.2).

| Campo                  | Contenido | Guía                                                                                                    |
|------------------------|-----------|---------------------------------------------------------------------------------------------------------|
| Código                 |           | H-NN; NC-AAAA-NNN en T08 si es no conformidad.                                                          |
| Título                 |           | Frase breve y descriptiva.                                                                              |
| Condición              |           | Qué se ha encontrado, con hechos y cifras.                                                              |
| Criterio               |           | Requisito incumplido, con referencia exacta.                                                            |
| Causa                  |           | Análisis preliminar; la causa raíz completa se trata con el documento 37.                               |
| Efecto                 |           | Decisión afectada, riesgo, cumplimiento o valor.                                                        |
| Evidencia              |           | Referencias AUD-AAAA-NNN/PT-NN de P59.                                                                  |
| Clasificación          |           | Observación · No conformidad menor · mayor · crítica, con la regla aplicada si se agrega o reclasifica. |
| Recomendación          |           | Qué debería corregirse.                                                                                 |
| Acción de la dirección |           | Acción, responsable y plazo.                                                                            |

(ejemplo ilustrativo) **H-02 · Respuestas dudosas sin revisión humana en el turno de noche.** Condición: 1 de 29 respuestas marcadas como dudosas en el periodo no tuvo revisión; el turno de noche carecía de supervisor designado durante tres semanas. Criterio: supervisión definida en P17 y criterio R6 correspondiente del documento 21. Causa: la baja del supervisor no activó sustitución. Efecto: respuestas a clientes sin la revisión aprobada en G5. Evidencia: PT-05. Clasificación: no conformidad menor; afecta a la supervisión humana, por lo que no se admite como condición de continuidad. Recomendación: asegurar la cobertura de la supervisión en todos los turnos. Acción: designación de suplentes y alerta de turno sin supervisor, responsable de operación de IA, 30 días.

## 8.1 Variante: auditoría del valor (43 §12)

Campos adicionales de la ficha:

| Campo                                         | Contenido                                                                                                                                                                                                                                                                                                | Guía |
|-----------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| Caso y código del importe                     | IA-AAAA-NNN; línea de valor en T12.                                                                                                                                                                                                                                                                      |      |
| Prueba de 43 §12.3 afectada                   | Fórmula y fuentes · Línea base y atribución · Estado y vigencia · Materialización · Exclusividad · Coste completo · Presentación.                                                                                                                                                                        |      |
| Importe y estado presentados                  | Validado · declarado · estimado.                                                                                                                                                                                                                                                                         |      |
| Importe y estado correctos según la auditoría |                                                                                                                                                                                                                                                                                                          |      |
| ¿Afecta a cifras ya presentadas al consejo?   | Sí · No. Si es Sí, la oficina de IA presenta en la siguiente sesión la cifra corregida junto a la presentada, con la explicación.                                                                                                                                                                        |      |
| Tratamiento mínimo (43 §12.4)                 | Error sin impacto en decisiones: menor · Importe como validado sin validación o caducado: mayor · Doble conteo o capacidad liberada sumada en el neto con impacto en decisiones: mayor · Alteración deliberada de cifras o de criterios de parada: al menos mayor y comunicación a la comisión delegada. |      |

## 8.2 Variante: auditoría posterior a un *gate* (21 §10.7)

| Campo                                  | Contenido                                                                                                                                                                                                                                       | Guía |
|----------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| Iniciativa, <i>gate</i> e iteración    | IA-AAAA-NNN · Gn · iteración.                                                                                                                                                                                                                   |      |
| Decisión auditada y fecha              | Resultado registrado en P29.                                                                                                                                                                                                                    |      |
| Criterio o regla afectada              | Código Gn.nn, R6.nn o regla EV.                                                                                                                                                                                                                 |      |
| ¿Invalida la decisión?                 | Sí · No. Todo hallazgo que invalida una decisión de <i>gate</i> es, como mínimo, no conformidad mayor (21 §10.5).                                                                                                                               |      |
| Efecto sobre el <i>gate</i> (21 §10.6) | Crítica: <i>gate</i> invalidado · Mayor que invalida: la iniciativa vuelve a Pendiente de <i>gate</i> y se verifica de nuevo; si está en producción, el comité decide si mantiene la operación con contención · Menor: la decisión se mantiene. |      |

| Campo       | Contenido | Guía |
|-------------|-----------|------|
| Responsable |           |      |

09

## Observaciones y recomendaciones

| Nº | Observación | Recomendación | Decisión de la dirección (actúa · no actúa) |
|----|-------------|---------------|---------------------------------------------|
|----|-------------|---------------|---------------------------------------------|

10

## Seguimiento de hallazgos anteriores

| Auditoría y hallazgo | Clase | Acción comprometida | Plazo | Estado                                                                               | Comentario |
|----------------------|-------|---------------------|-------|--------------------------------------------------------------------------------------|------------|
|                      |       |                     |       | Corregido · Corregido sin eficacia demostrada · En plazo · Vencido · Riesgo aceptado |            |

11

## Respuesta de la dirección

| Hallazgo | Acción | Responsable | Plazo | ¿De acuerdo con el hallazgo? (Sí · No) | Si No, posición de la dirección y posición del auditor |
|----------|--------|-------------|-------|----------------------------------------|--------------------------------------------------------|
| H-01     |        |             |       |                                        |                                                        |
| H-02     |        |             |       |                                        |                                                        |

Aceptar el riesgo en lugar de corregir solo es posible si el órgano con nivel suficiente (30 §7.2) lo acepta expresamente y el incumplimiento no es legal; el hallazgo se cierra como «riesgo aceptado», no como «corregido» (38 §10).

## Conclusión

| Campo                                   | Contenido                                                                                                                                                                                             | Guía |
|-----------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------|
| <b>Opinión del auditor</b>              | Conclusión sobre el objeto y el periodo, coherente con los hallazgos y las limitaciones. En auditorías posteriores de <i>gates</i> , conclusión sobre el funcionamiento de las puertas en el periodo. |      |
| <b>Resultado</b>                        | Conforme · Conforme con observaciones · No conforme.                                                                                                                                                  |      |
| <b>Consecuencia</b>                     | Cierre del expediente · Seguimiento de acciones · Plan de acción y reauditoría; en R6, adelantar G7 si afecta a controles del sistema.                                                                |      |
| <b>No conformidades abiertas en T08</b> | Códigos NC-AAAA-NNN.                                                                                                                                                                                  |      |

## Distribución y anexos

| Tipo de auditoría | Destinatarios (38 §9.3)                                                                                      |
|-------------------|--------------------------------------------------------------------------------------------------------------|
| De continuidad    | Patrocinador, responsable de operación, responsable de riesgos; comité de IA si el resultado es No conforme. |
| Del marco         | Comité de IA, comisión delegada; resumen al consejo en C5.                                                   |
| Temática          | Comité de IA, comisión delegada, responsables de los sistemas afectados.                                     |
| De proveedor      | Responsable de la relación con el proveedor, segunda línea; comité de IA si es N3.                           |
| Del valor         | Comité de IA y comisión delegada; se incorpora a C5 (43 §12).                                                |

Anexos: evidencias revisadas, muestras, resultados de pruebas técnicas y declaraciones de independencia (P41).

## Criterios de calidad

| # | Comprobación                                                                                                                | Estado                                     |
|---|-----------------------------------------------------------------------------------------------------------------------------|--------------------------------------------|
| 1 | Cada hallazgo tiene condición, criterio, causa, efecto, evidencia y clasificación, y remite a un papel de trabajo.          | Cumple · No cumple · No aplica · Pendiente |
| 2 | La clasificación aplica el efecto más grave y las reglas de agregación, reincidencia y reclasificación.                     |                                            |
| 3 | El resultado es coherente con los hallazgos: ninguna mayor o crítica con resultado Conforme o Conforme con observaciones.   |                                            |
| 4 | Las limitaciones están declaradas con su efecto en la conclusión.                                                           |                                            |
| 5 | Cada no conformidad está registrada en T08 con NC-AAAA-NNN vinculado a la auditoría.                                        |                                            |
| 6 | La respuesta de la dirección tiene acción, responsable y plazo por hallazgo, y las discrepancias muestran ambas posiciones. |                                            |
| 7 | Las no conformidades críticas se comunicaron antes del informe.                                                             |                                            |
| 8 | En la auditoría del valor, las cifras corregidas que afectan al consejo tienen fecha de presentación.                       |                                            |

## Aprobación y verificación

| Función                        | Rol en SEVEN-G                                                   | Nombre y cargo | Fecha | Firma o referencia |
|--------------------------------|------------------------------------------------------------------|----------------|-------|--------------------|
| Emite la opinión               | Auditor de IA (auditor principal)                                |                |       |                    |
| Revisa la calidad              | Responsable de auditoría de IA                                   |                |       |                    |
| Responde y compromete acciones | Dirección responsable del objeto auditado                        |                |       |                    |
| Aprueba las acciones           | Oficina de IA · Comité de IA · Comisión delegada, según la clase |                |       |                    |

Separación de funciones: quien responde por la dirección no modifica la opinión ni la clasificación; si discrepa, su posición figura junto a la del auditor.

16

# Control de versiones

## Documento cumplimentado

| Versión | Fecha | Autor | Cambios |
|---------|-------|-------|---------|
|---------|-------|-------|---------|

## Plantilla

| Versión | Fecha      | Cambios                                                                                                                                                                                                 |
|---------|------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 0.1     | 19-09-2026 | Primera versión. Aplica la estructura de informe y la ficha de hallazgo de 38 §9, la clasificación y el seguimiento de 38 §8 y §10, el contenido mínimo de 21 §10.7 y la auditoría del valor de 43 §12. |

# Fuentes externas citadas

Enlaces a la fuente oficial o primaria, comprobados antes de publicar. Verifique siempre la versión vigente en la fecha de uso.

**Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo, de 27 de abril de 2016, relativo a la protección de las personas físicas en lo que respecta al tratamiento de datos personales y a la libre circulación de estos datos y por el que se deroga la Directiva 95/46/CE (Reglamento general de protección de datos)** · <https://eur-lex.europa.eu/eli/reg/2016/679/oj/spa> · Parlamento Europeo y Consejo de la UE · 27-04-2016

**Reglamento (UE) 2024/1689 del Parlamento Europeo y del Consejo, de 13 de junio de 2024, por el que se establecen normas armonizadas en materia de inteligencia artificial (Reglamento de Inteligencia Artificial)** · <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/spa> · Parlamento Europeo y Consejo de la UE · 13-06-2024